Marsvin - diagram set, 12 October 2026

Twenty-four diagrams, redrawn against the code as it stands on 12 October 2026 (the `marsvin-web` project, commit `03c9513`). Each `.mermaid` file renders at https://mermaid.live, or paste it into a ```` ```mermaid ```` block. Ready-made PNGs are in `png/`, and `marsvin-diagrams.pdf` has them all in one file.

The previous sets (`diagrams 09102026`, `diagrams 02102026`) are left untouched for comparison.

File	Diagram	Status vs 9 Oct
`marsvin-er-diagram`	ER diagram, 15 tables	updated
`marsvin-domain-model`	Class diagram, entities and enums	updated
`marsvin-class-services`	Class diagram, stores and DI lifetimes	updated
`marsvin-dfd`	Data flow diagram with trust boundaries	updated
`marsvin-navigation`	Navigation and access-control map	updated
`marsvin-activity-email-language`	Activity, which language an email is written in	**new**
`marsvin-sequence-donation`	Sequence, a donation and its thank-you email	**new**
`marsvin-sequence-checkout`	Sequence, checkout (guest or customer)	updated
`marsvin-sequence-order-status`	Sequence, order status and cancelling	updated
`marsvin-sequence-session-check`	Sequence, the per-request session check	updated
`marsvin-sequence-chat`	Sequence, the support chat (Pip)	unchanged
`marsvin-sequence-login`	Sequence, login (email link or TOTP)	updated
`marsvin-sequence-totp-enrollment`	Sequence, 2FA enrol / disable	unchanged
`marsvin-sequence-register`	Sequence, registration	updated
`marsvin-sequence-password-reset`	Sequence, forgot / reset password	updated
`marsvin-sequence-admin-edit`	Sequence, admin edit with audit log	unchanged
`marsvin-sequence-add-to-cart`	Sequence, add to cart	unchanged
`marsvin-sequence-inactivity-cleanup`	Sequence, GDPR account deletion	updated
`marsvin-state-animal`	State machine, Animal	unchanged
`marsvin-state-order`	State machine, Order	updated
`marsvin-deployment`	Deployment	updated
`marsvin-activity-checkout`	Activity diagram	updated
`marsvin-ssd-place-order`	System sequence diagram	updated
`marsvin-communication-checkout`	Communication diagram	updated

All 24 PNGs in this set were rendered again, the unchanged ones included, so the set is drawn in one style.

What changed since 9 October

- **Emails follow the language of the site.** Every email is written in Danish or English. The EN / DA choice used to live only in the browser (`localStorage`); the toggle now also sets a small cookie, `marsvin-lang`, holding `da` or `en`, which `SiteLanguage` reads. Which language a mail gets depends on who caused it - see the new activity diagram:

    - the recipient, in their own browser (login link, new account, password reset, profile change, order confirmation, donation, cancelling their own order): the cookie of that request;
    - staff, about an order: `Orders.PlacedInEnglish`, saved at checkout;
    - someone else about an account (a changed shift, a day-off request to the admins, the failed-login warning), or the inactivity job: `Users.PrefersEnglish`.
- **Two new columns.** `Users.PrefersEnglish` and `Orders.PlacedInEnglish`, both `BIT NOT NULL DEFAULT 0` (Danish). Still 15 tables. The account's value is kept current on every signed-in request (`AuthCookiePrincipal.RevalidateAsync`), written only when the cookie holds one of the two values and differs from what is stored.
- `IEmailSender.SendAsync` **takes the language.** The subject and body arrive already written; the flag only picks the footer the sender adds (address, opening hours).
- **A donation sends a thank-you.** When the giver leaves an email address, `/Stoet` sends a fixed-wording thank-you: the amount, or where and when to hand things in. Until now the donation form deliberately sent no mail. New sequence diagram, a new flow in the DFD, and a new attacker arrow for it.
- **Free shipping from 2,000 kr.** `ShippingCalculator.FreeShippingThreshold` was 499.
- **Tests.** 696, was 586: the admin pages (what each handler saves, refuses and audits), every `/Admin` page tried as visitor, customer, employee and admin, the rate limits, the error pages, and the language of every email.
- **Smaller.** The cart keeps its scroll position when a quantity changes (`cart-quantity.js`, per-tab `sessionStorage`); the privacy page names the language cookie.

STRIDE table for the DFD

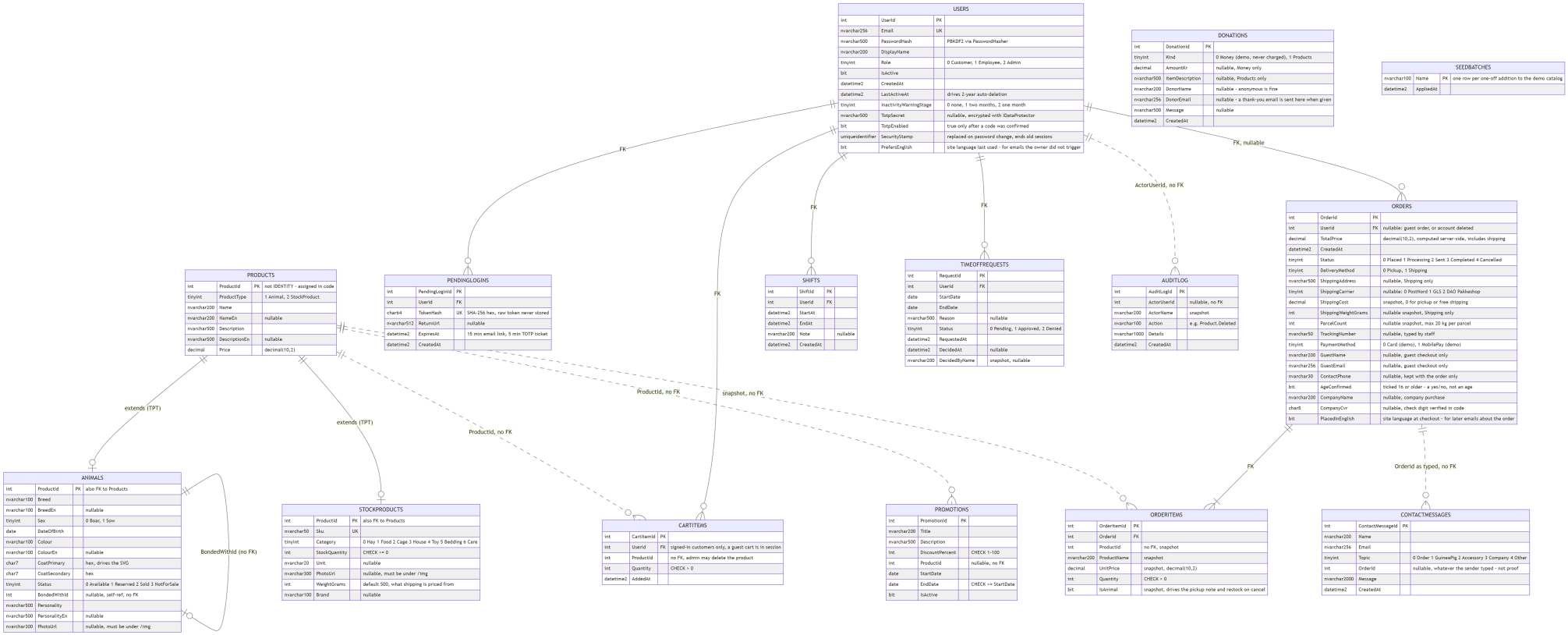
Letter	Where	Control in the code
Spoofing	Attacker to 1.0	PBKDF2, reCAPTCHA, per-email lockout, per-IP limiter, emailed link or TOTP
Spoofing	Stolen cookie to 0.0	HttpOnly cookie, security stamp replaced on password change, 30 min idle / 8 h max
Spoofing	Attacker to 11.0 to SMTP	A donation mail comes from the shop to an address the sender chose: fixed wording, none of the giver's free text repeated, name kept to one line, rate limited, optional reCAPTCHA
Tampering	Kunde to 3.0 / 4.0	Prices, stock and shipping cost worked out in the transaction, `ValidateLine`, antiforgery
Tampering	Attacker to 2.0	Filter, sort and page parameters matched against known values
Tampering	Language cookie to 0.0	Compared against `da` and `en` only, never echoed; anything else counts as not set
Repudiation	5.0 to D5	`AuditLog` with actor-name snapshot, including order status changes
Information disclosure	1.0 to SMTP, cookie	Token hashes only, TOTP secret encrypted, encrypted cookie, CSP, no-store
Information disclosure	4.0 to Gaest / Kunde	Own order only: `FindForUser`, or the session's own order id for a guest
Information disclosure	Attacker to 12.0	The chat is given public catalogue data only, and refuses the rest
Denial of service	Attacker to 0.0	Sliding-window limiters: 50 per minute per IP on auth and forms, 20 on the chat
Elevation of privilege	Attacker to 5.0	Deny by default, `[Authorize(Roles)]` on all 16 admin pages, role re-read per request

Known limits worth saying out loud

- `LoginLockoutTracker` and the guest session are in memory: they reset on restart and do not work across instances.
- The application connects to the database as the developer's Windows account, which owns it. A deployment should use an account limited to the tables it needs.
- The Admin role is all-or-nothing; there are no finer permissions.
- The authenticator app is optional for staff as well as customers.
- Nothing sets `Animals.Status = Reserved` automatically.
- **New:** the donation form can make the shop send one fixed-wording email to an address someone else typed in. Guest checkout already could; the rate limit is what bounds it. A stricter design would confirm the address first.
- **New:** product names in an English order email stay Danish - an order line stores only the Danish name.
- **New:** accounts and orders from before 12 October count as Danish until the account next uses the site in English.
- **New:** the JavaScript in `wwwroot/js` has no automated tests (there is no browser test setup), and neither has actual delivery through SMTP.

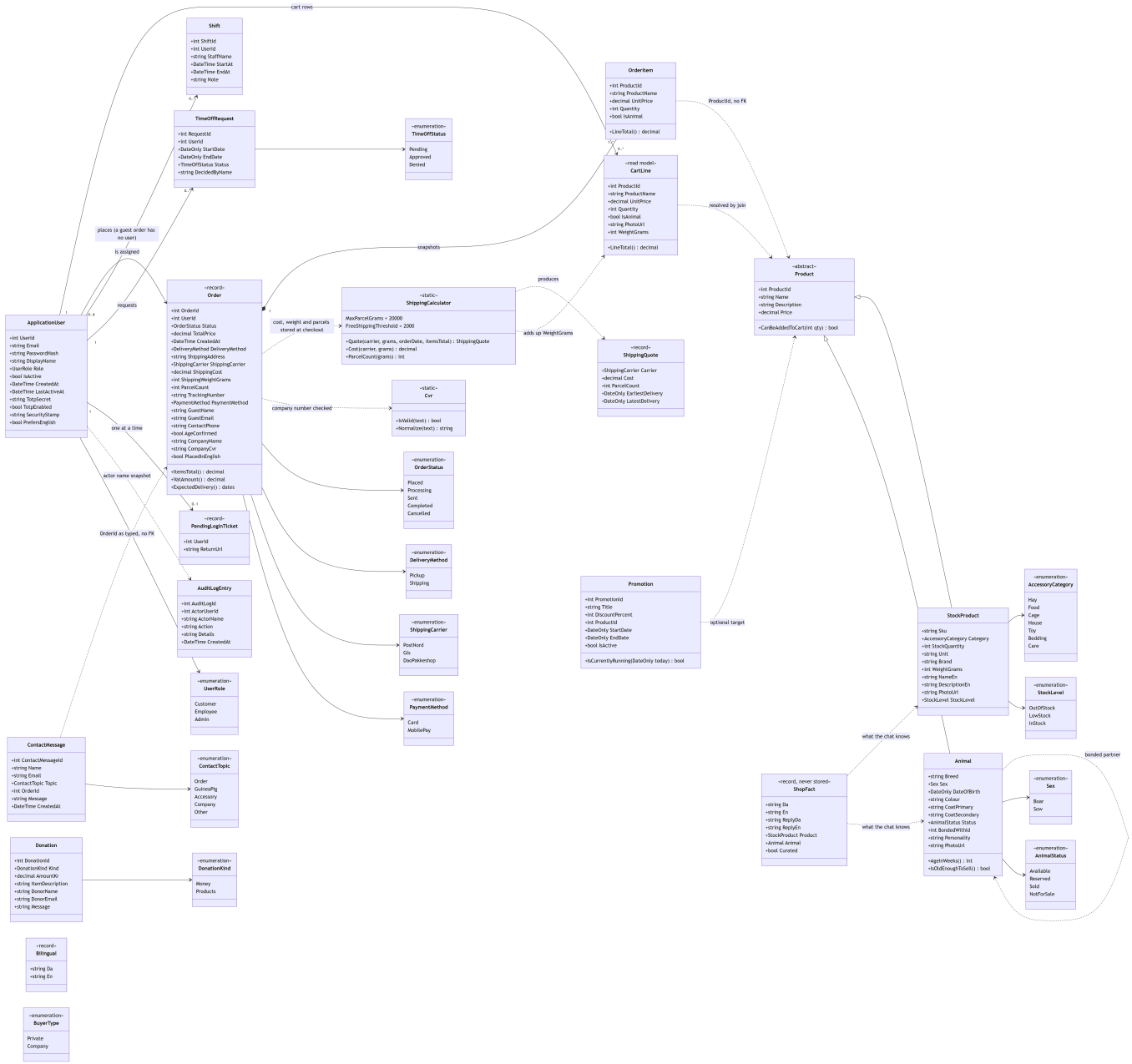
ER diagram, 15 tables

marsvin-er-diagram.mermaid



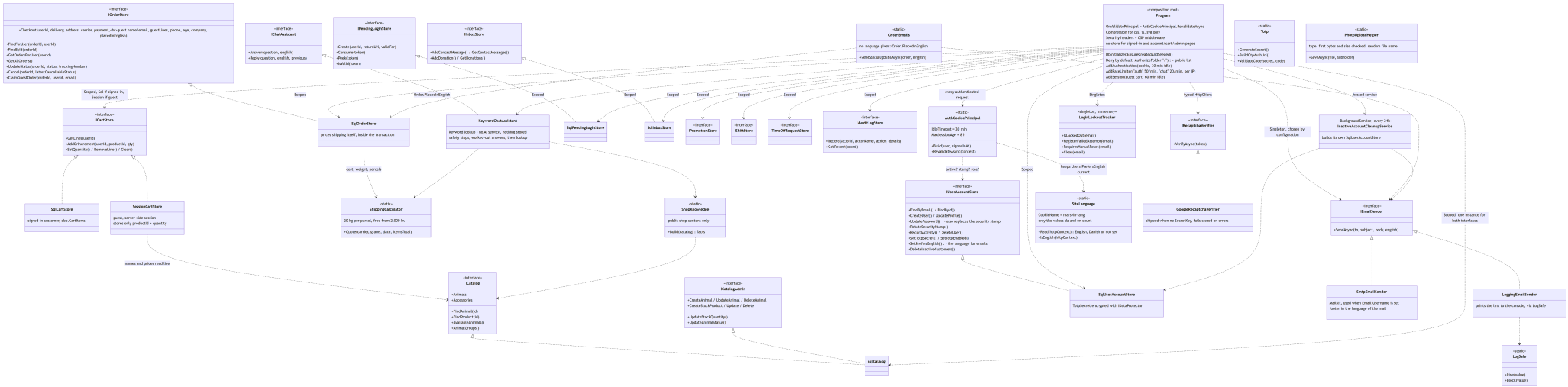
Class diagram, entities and enums

marsvin-domain-model.mermaid



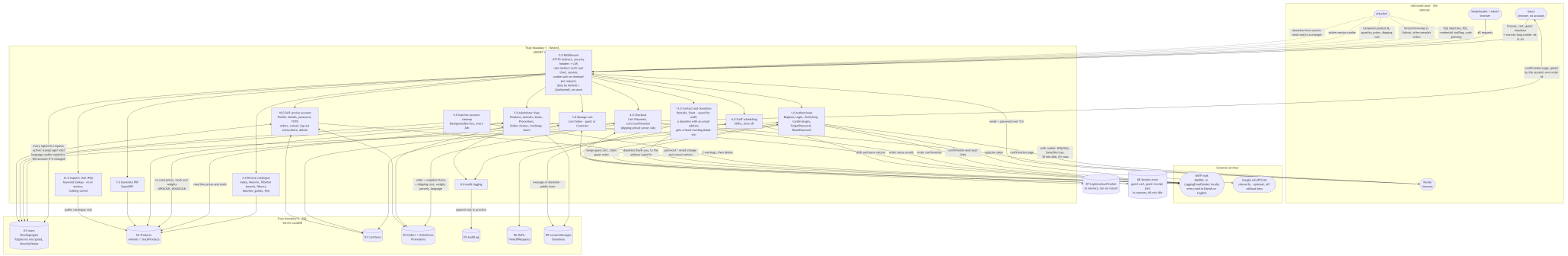
Class diagram, stores and DI lifetimes

marsvin-class-services.mermaid



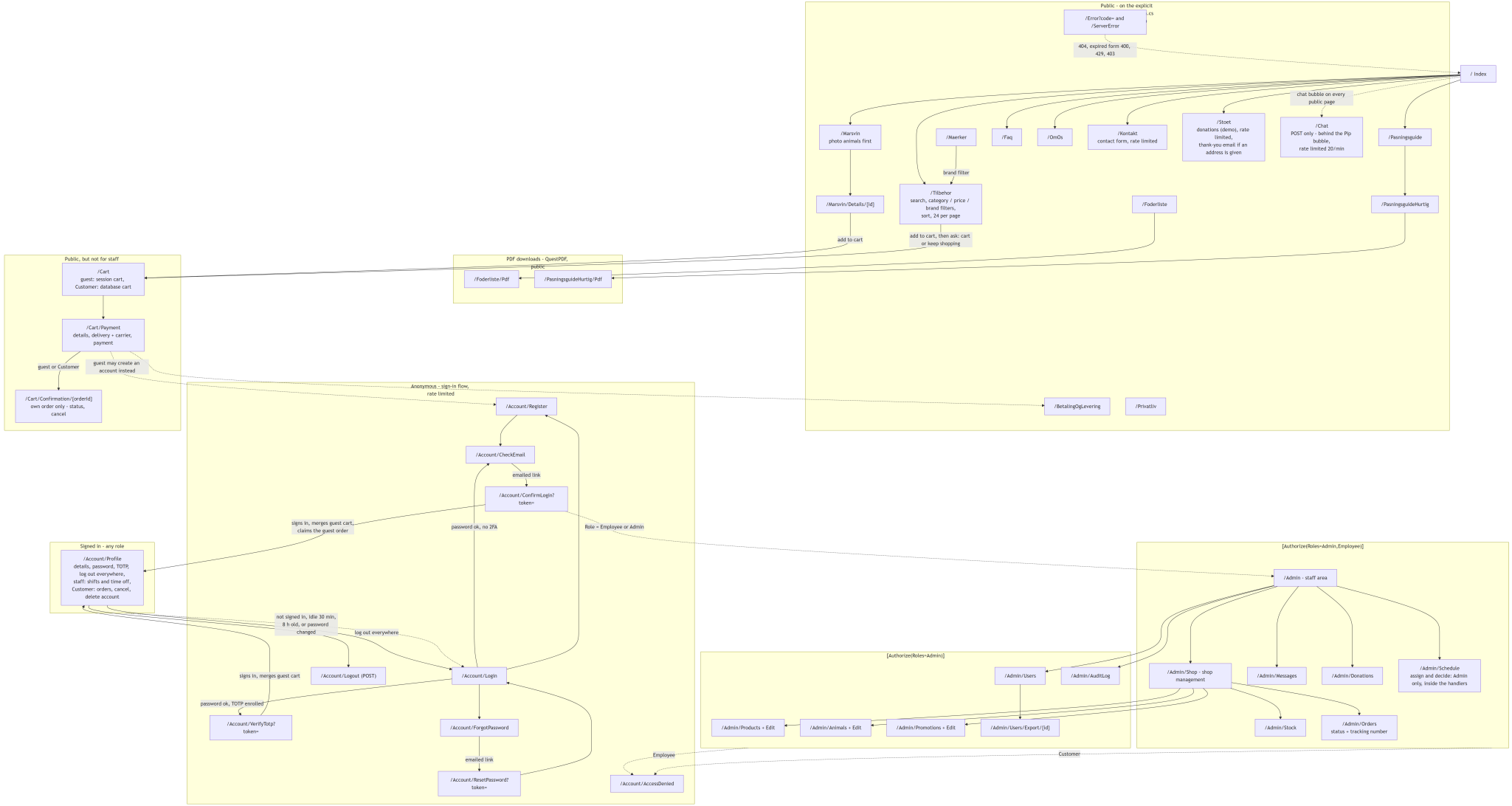
Data flow diagram with trust boundaries

marsvin-dfd.mermaid



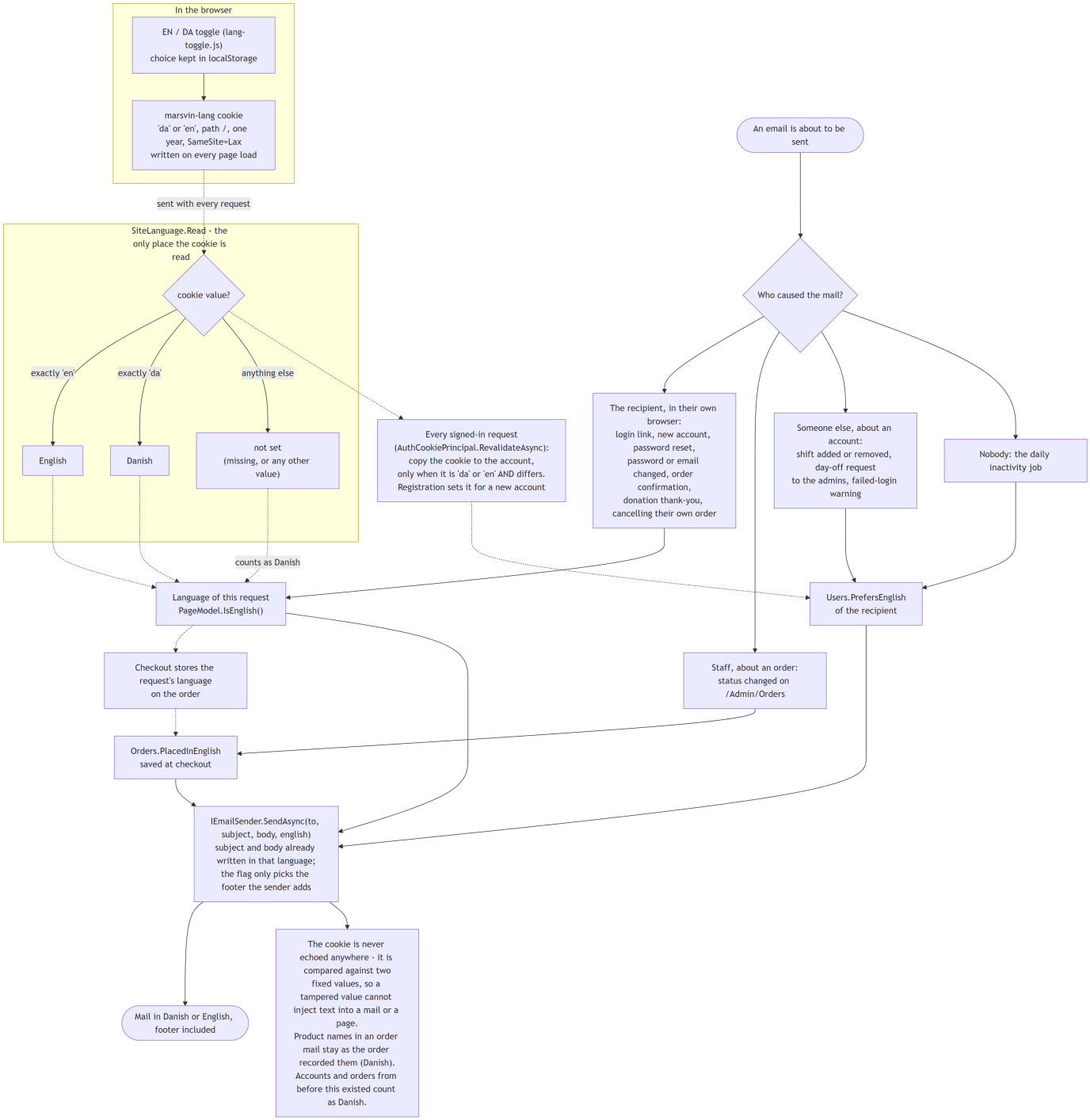
Navigation and access-control map

marsvin-navigation.mermaid



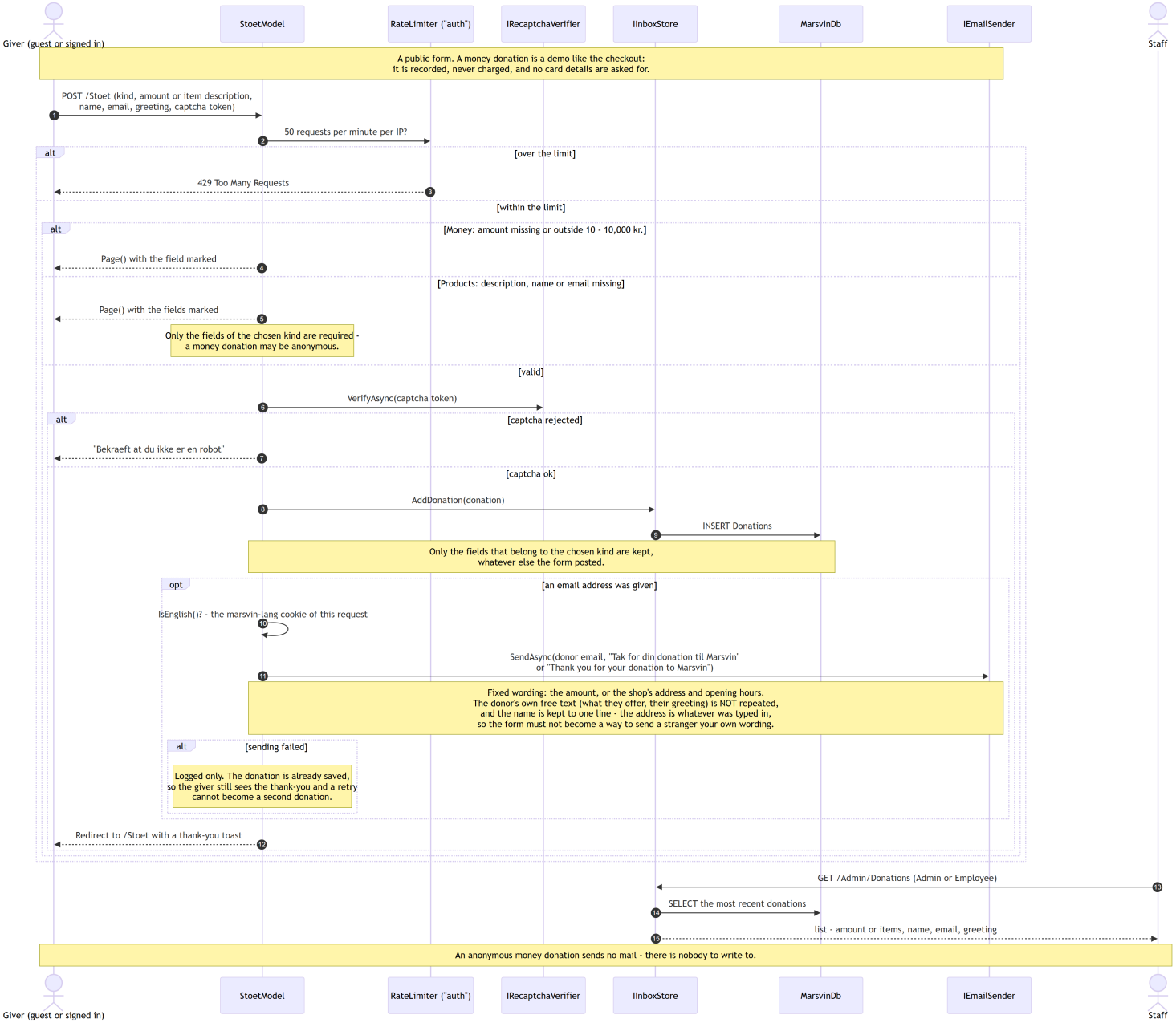
Activity, which language an email is written in

marsvin-activity-email-language.mermaid



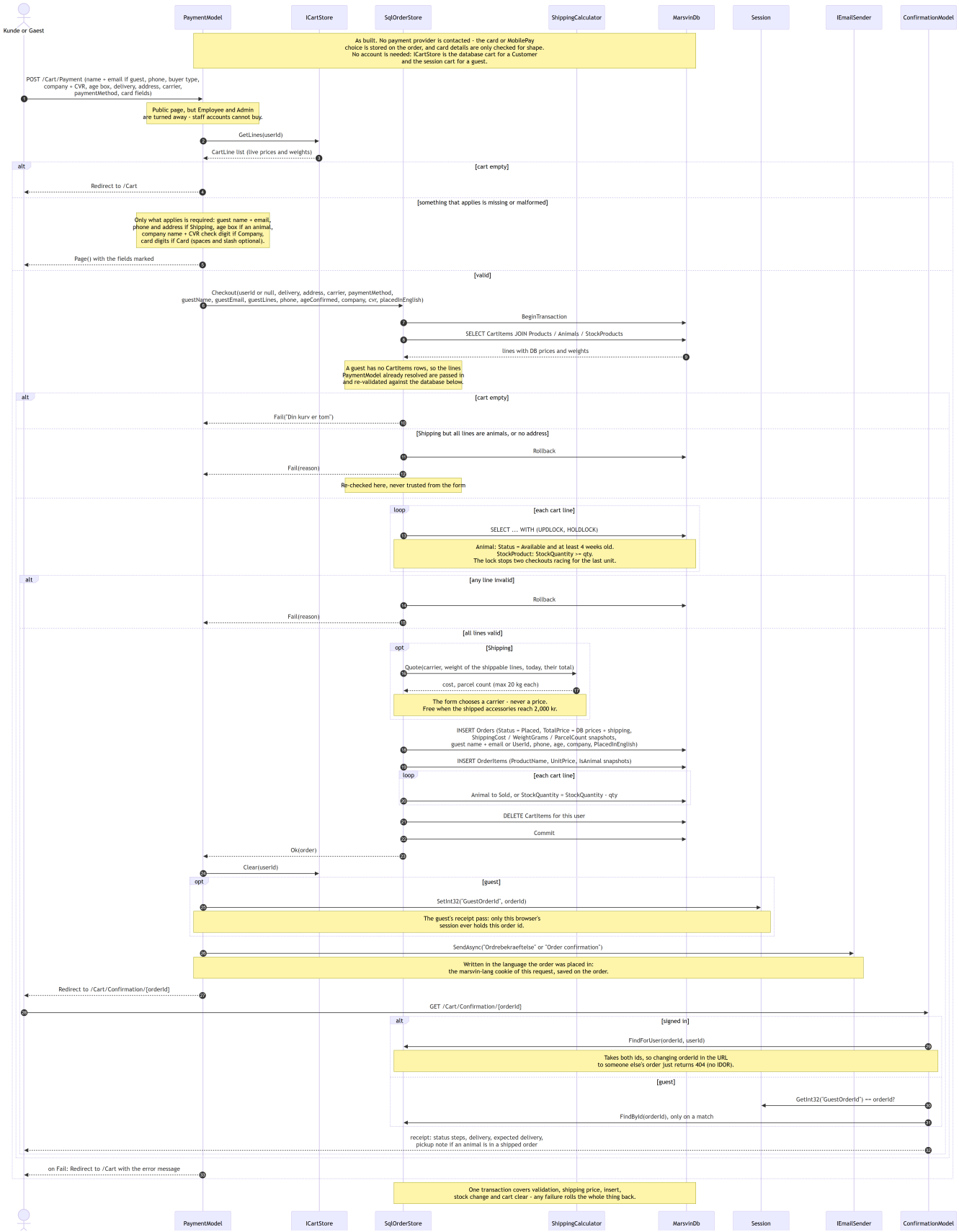
Sequence, a donation and its thank-you email

`marsvin-sequence-donation.mermaid`



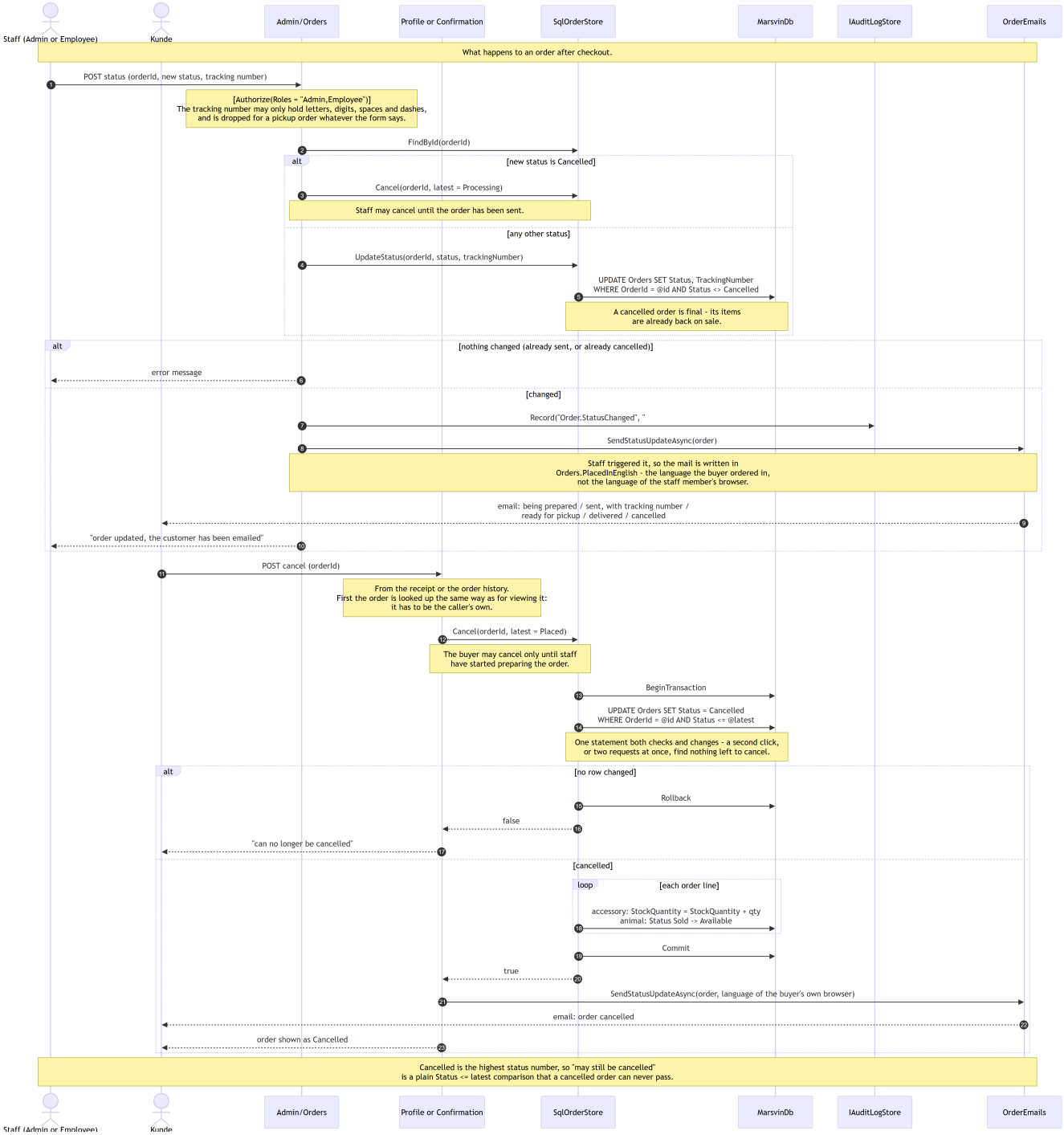
Sequence, checkout (guest or customer)

marsvin-sequence-checkout.mermaid



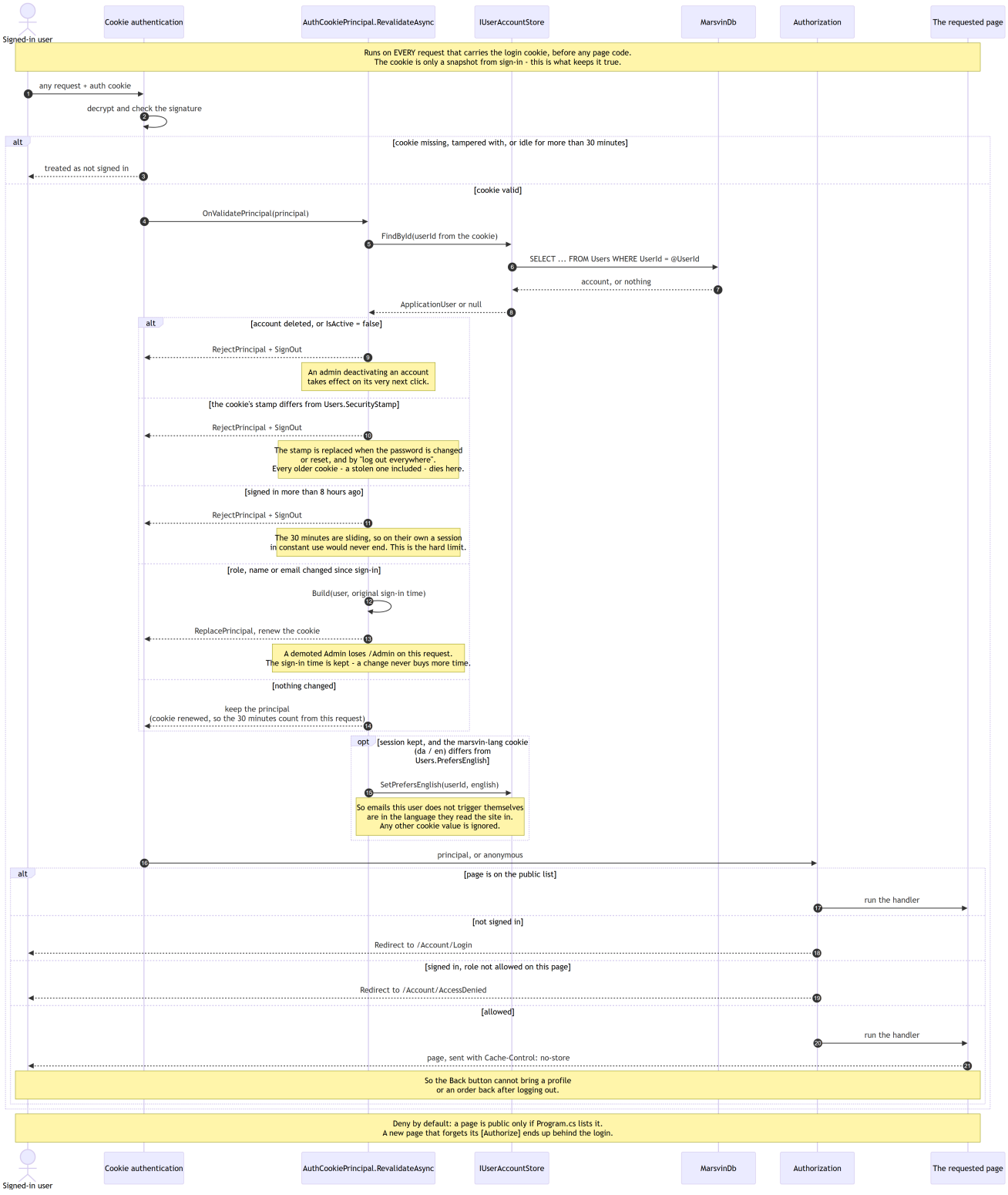
Sequence, order status and cancelling

marsvin-sequence-order-status.mermaid



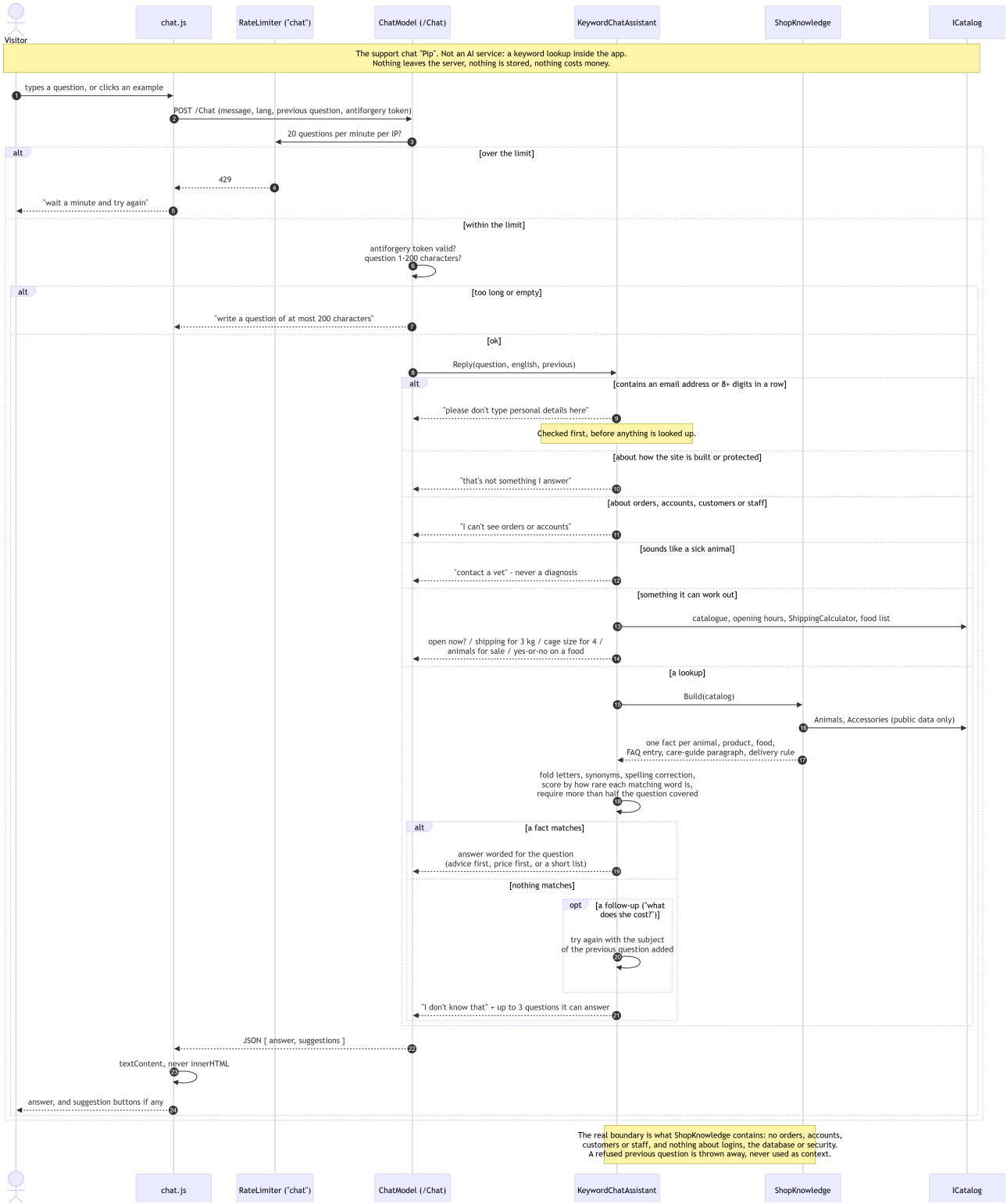
Sequence, the per-request session check

`marsvin-sequence-session-check.mermaid`



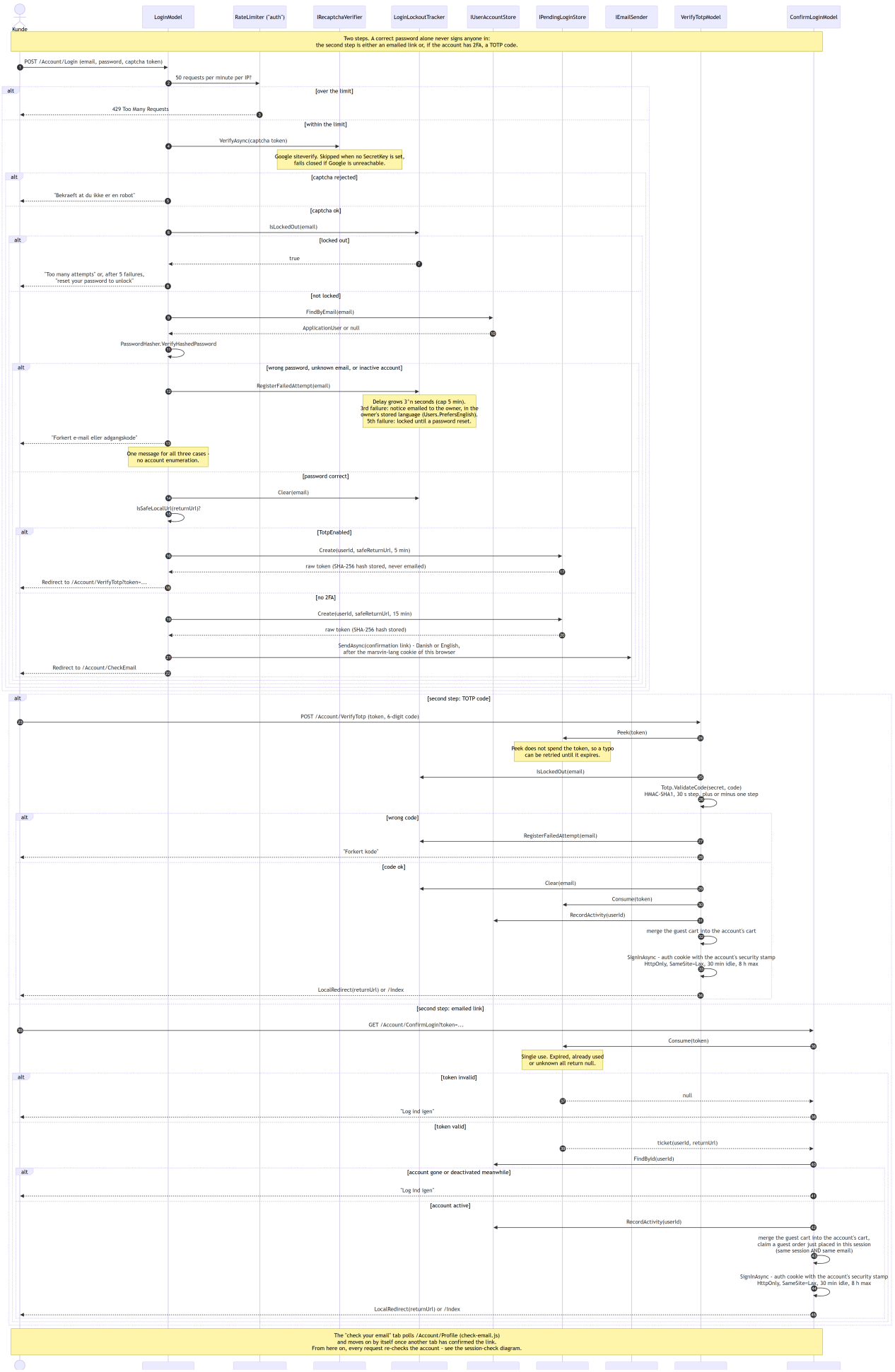
Sequence, the support chat (Pip)

marsvin-sequence-chat.mermaid



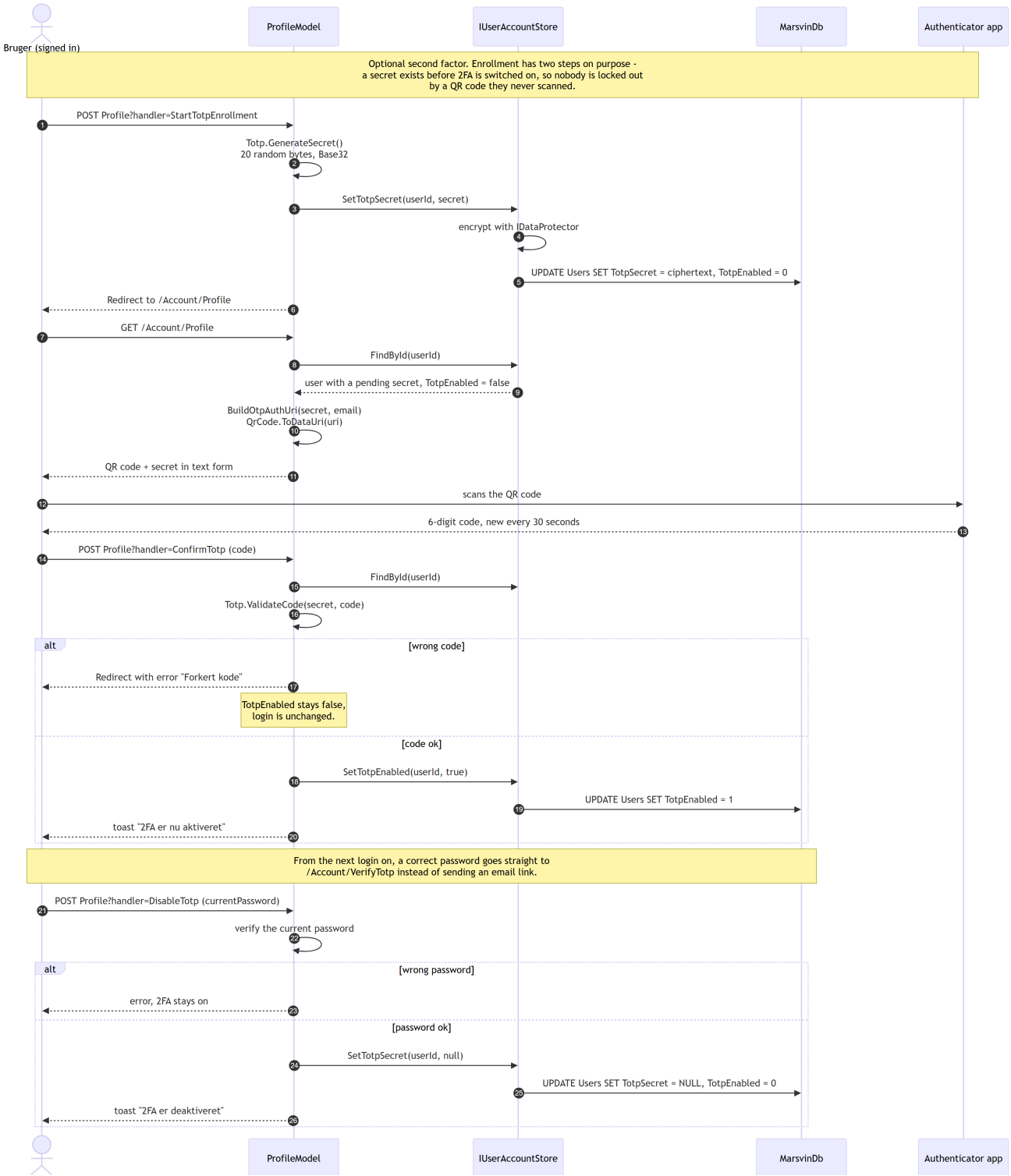
Sequence, login (email link or TOTP)

marsvin-sequence-login.mermaid



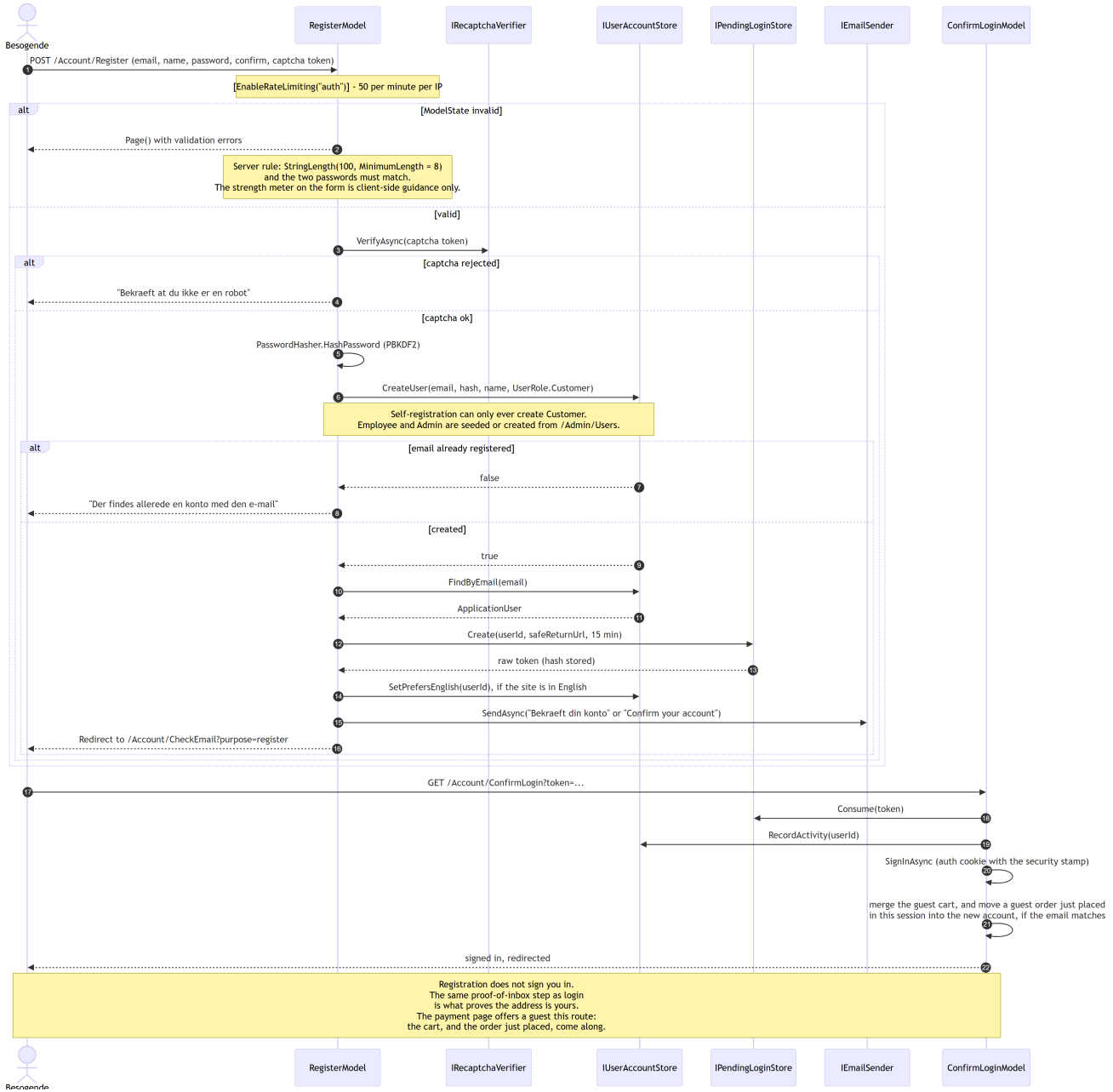
Sequence, 2FA enrol / disable

`marsvin-sequence-totp-enrollment.mermaid`



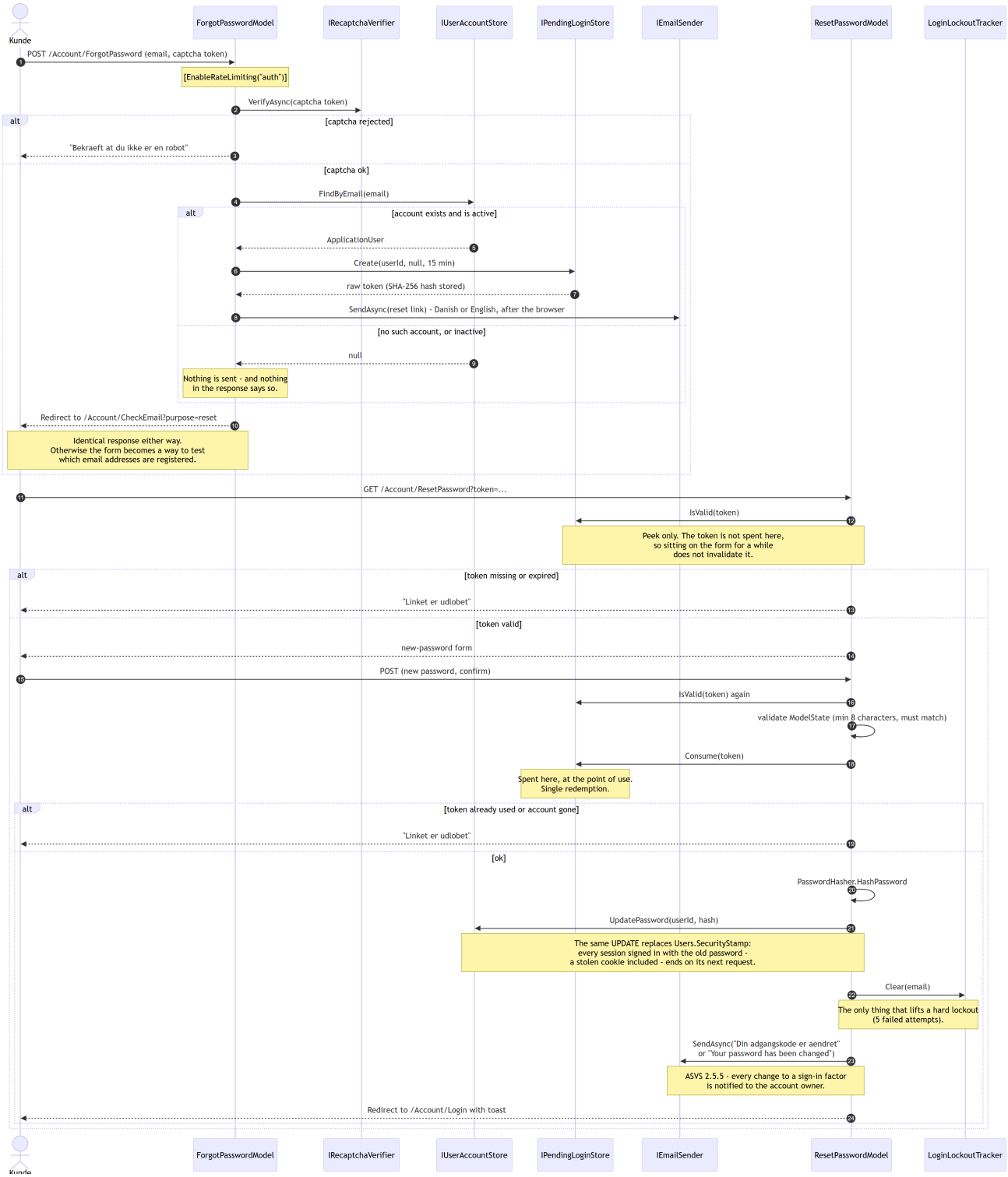
Sequence, registration

marsvin-sequence-register.mermaid



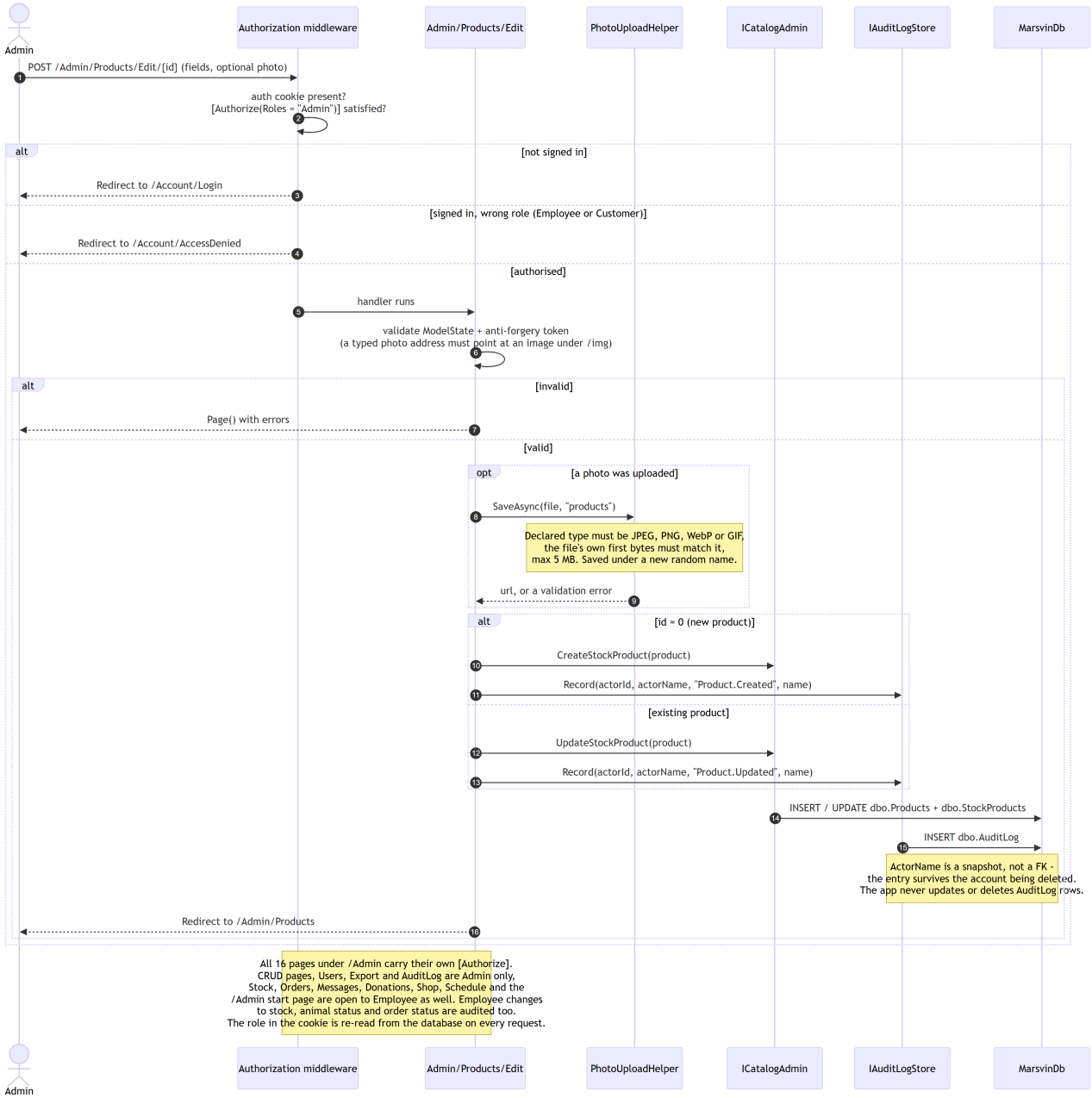
Sequence, forgot / reset password

marsvin-sequence-password-reset.mermaid



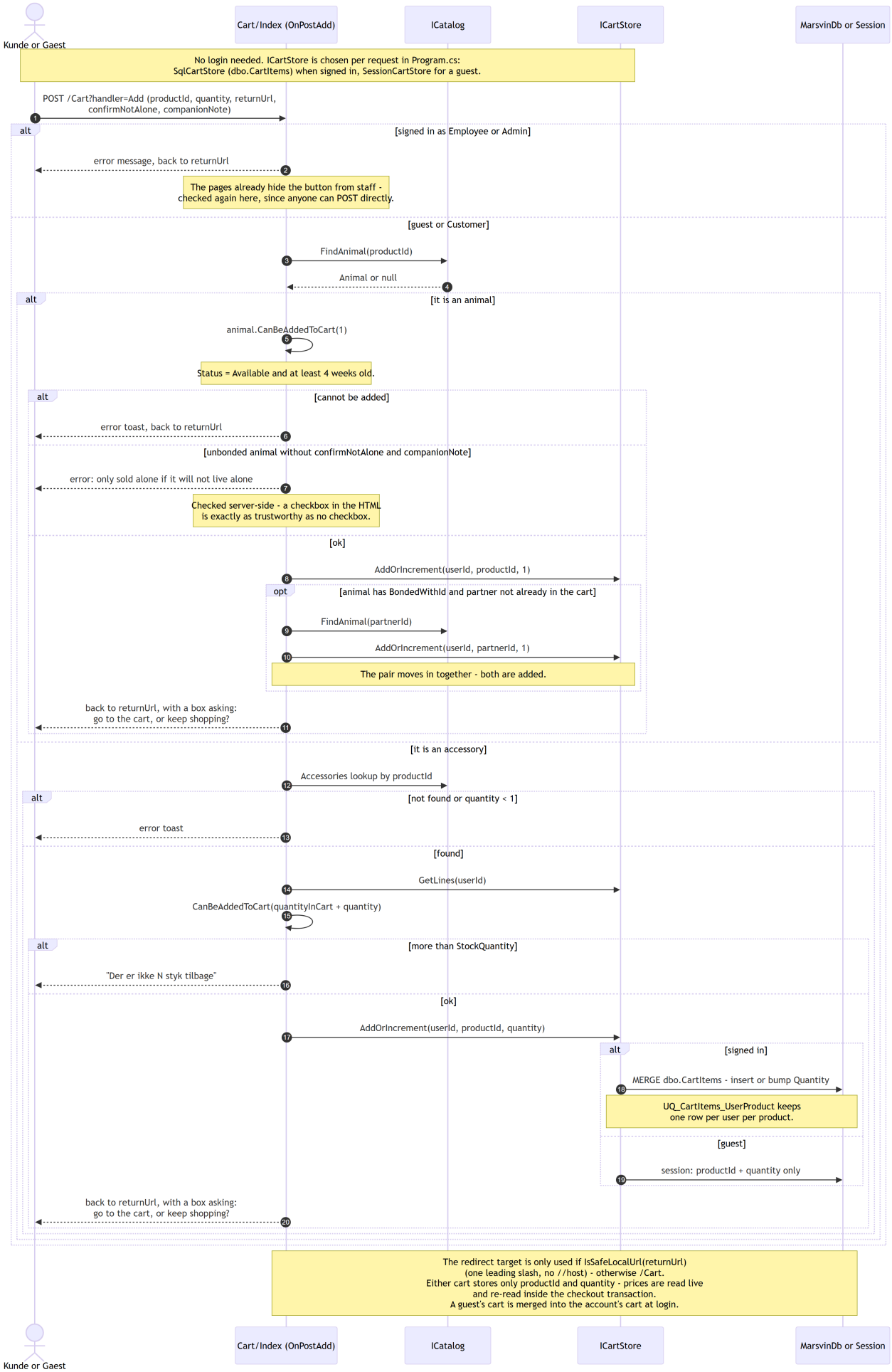
Sequence, admin edit with audit log

marsvin-sequence-admin-edit.mermaid



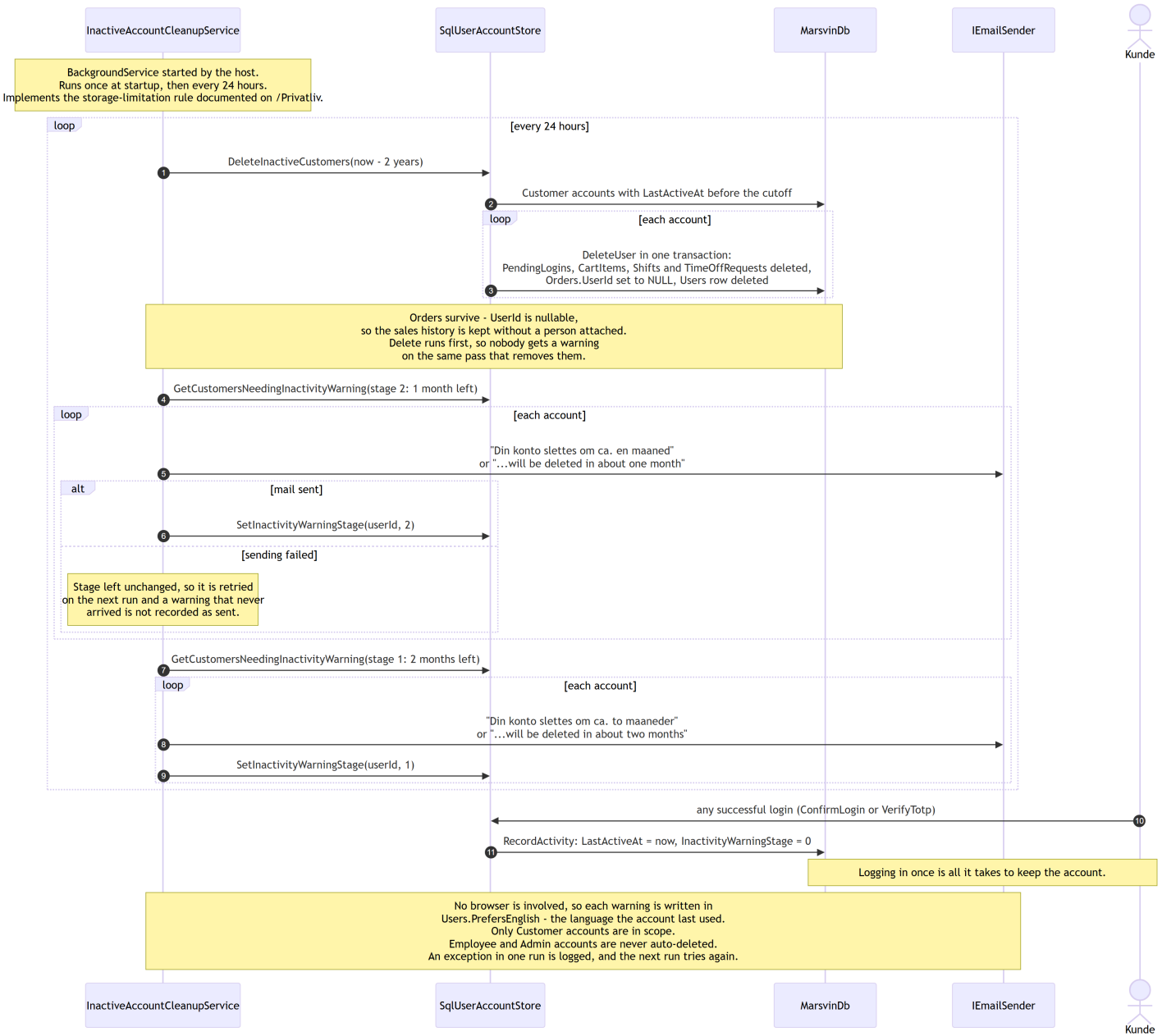
Sequence, add to cart

marsvin-sequence-add-to-cart.mermaid



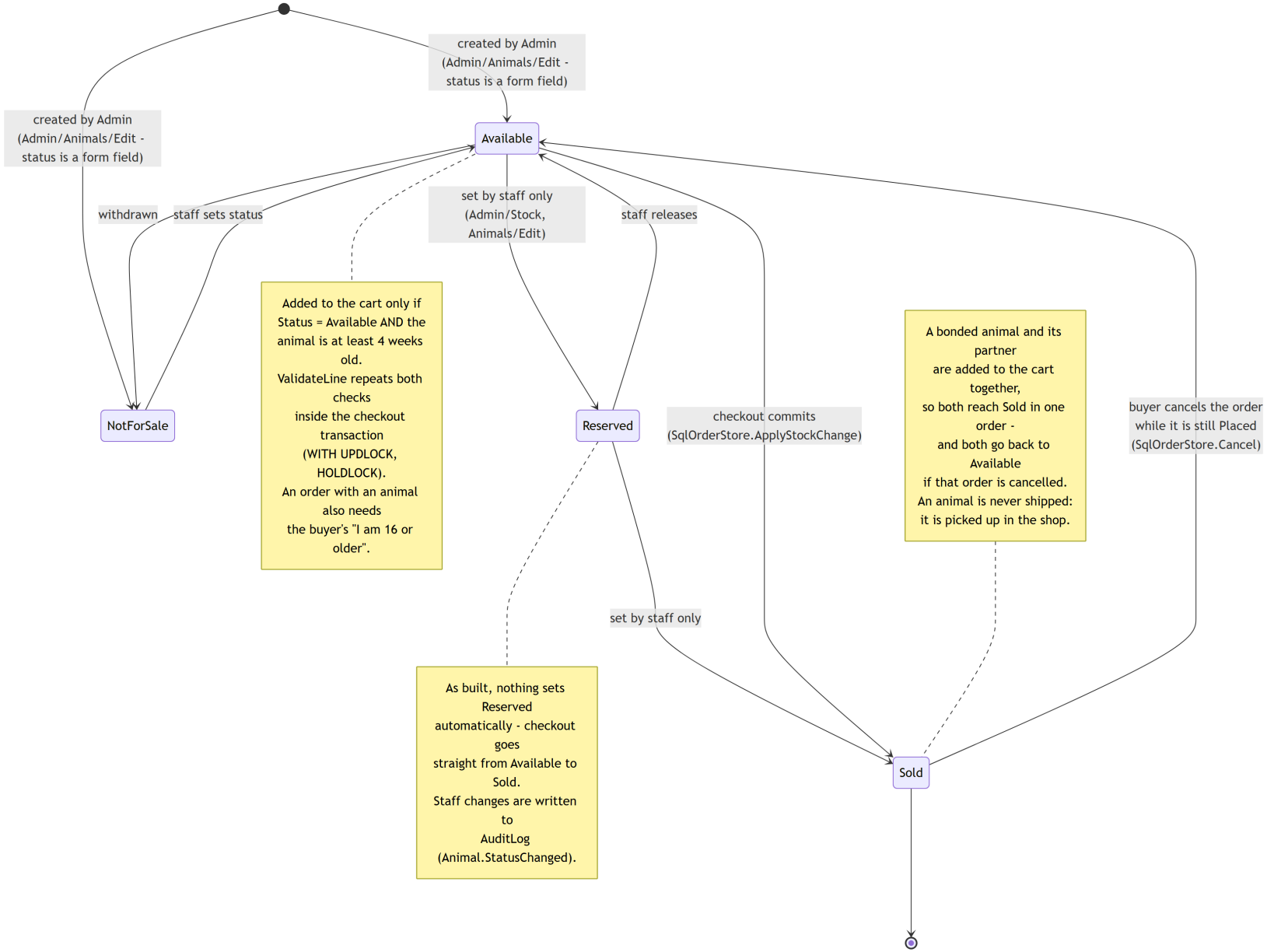
Sequence, GDPR account deletion

`marsvin-sequence-inactivity-cleanup.mermaid`



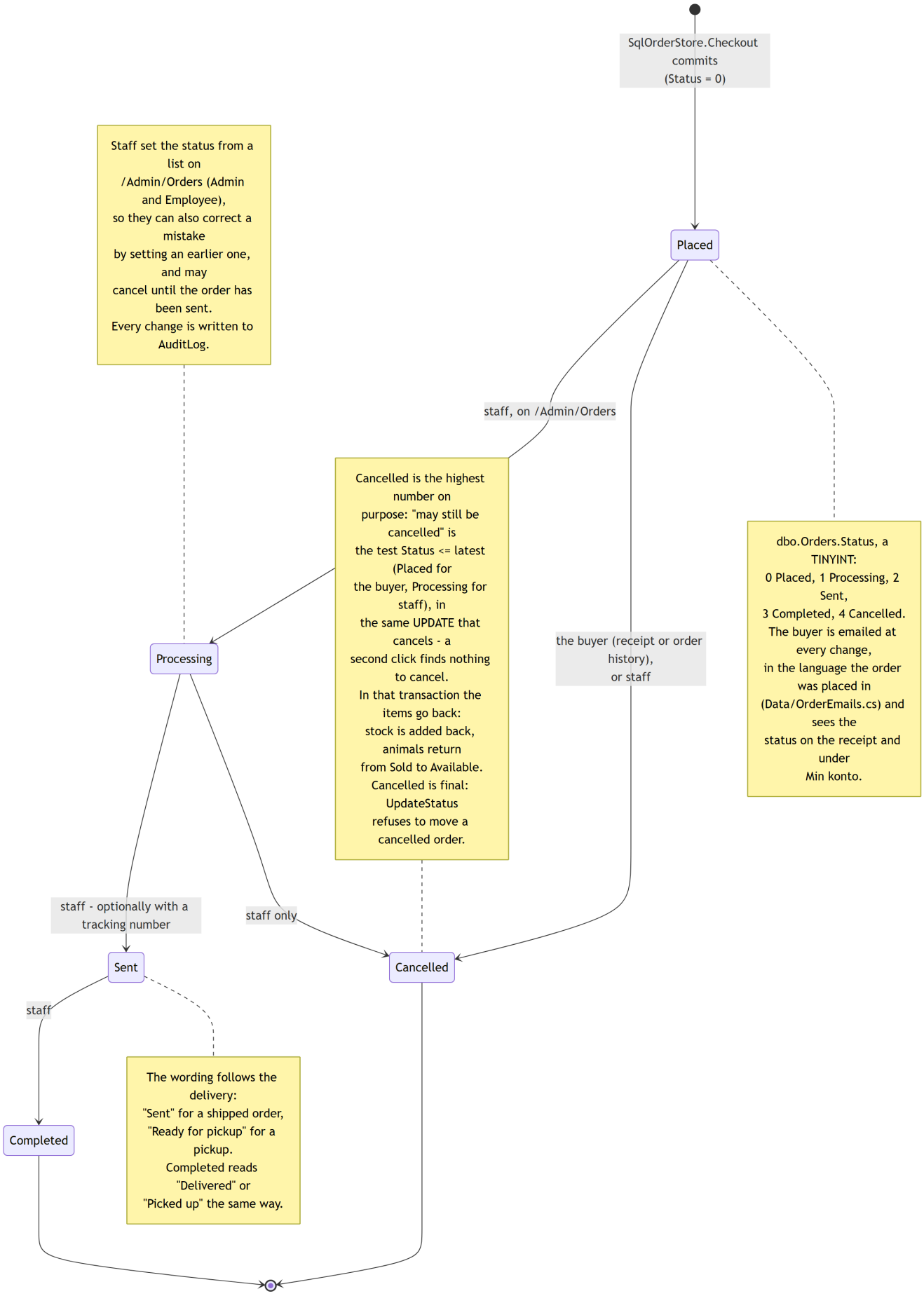
State machine, Animal

marsvin-state-animal.mermaid



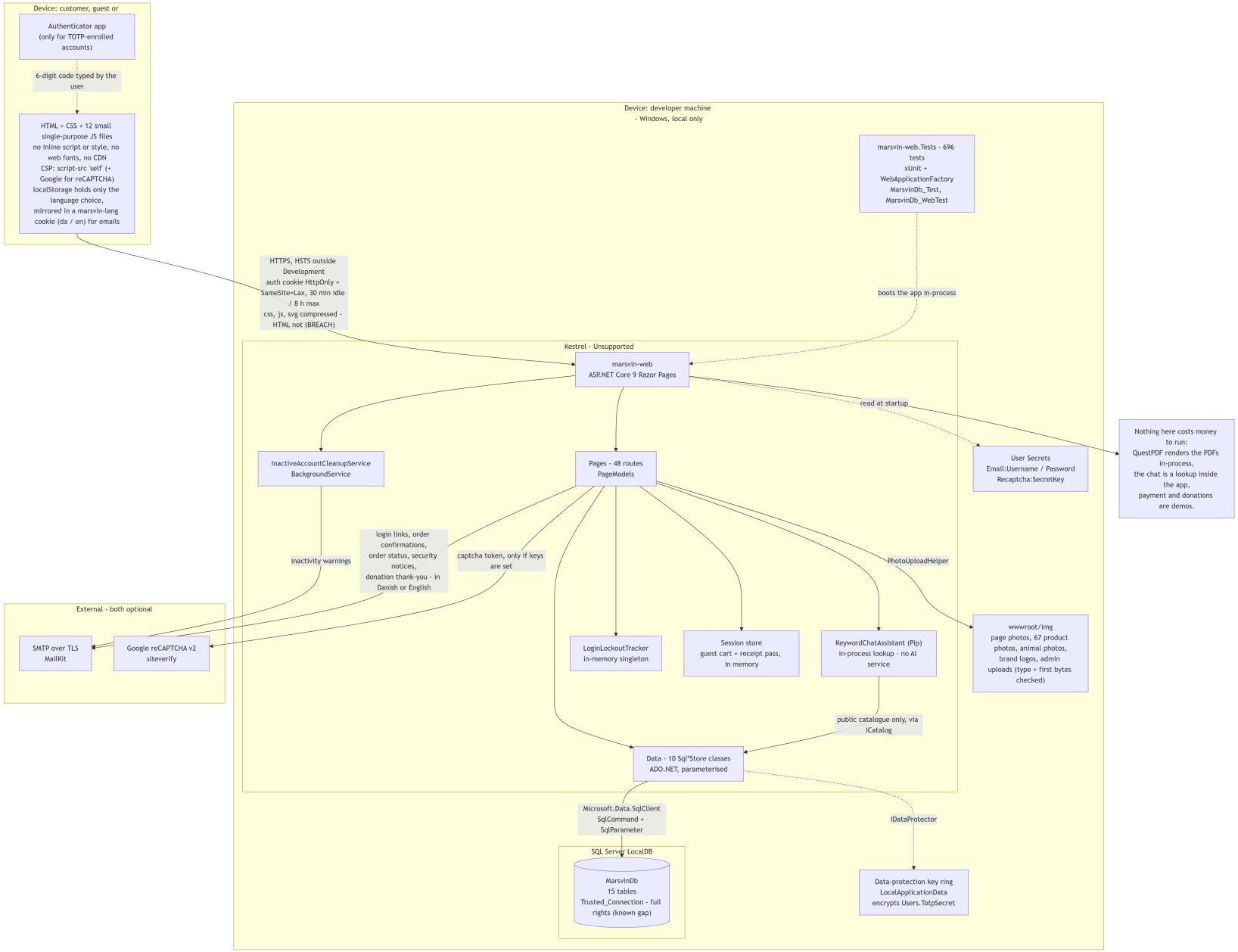
State machine, Order

marsvin-state-order.mermaid



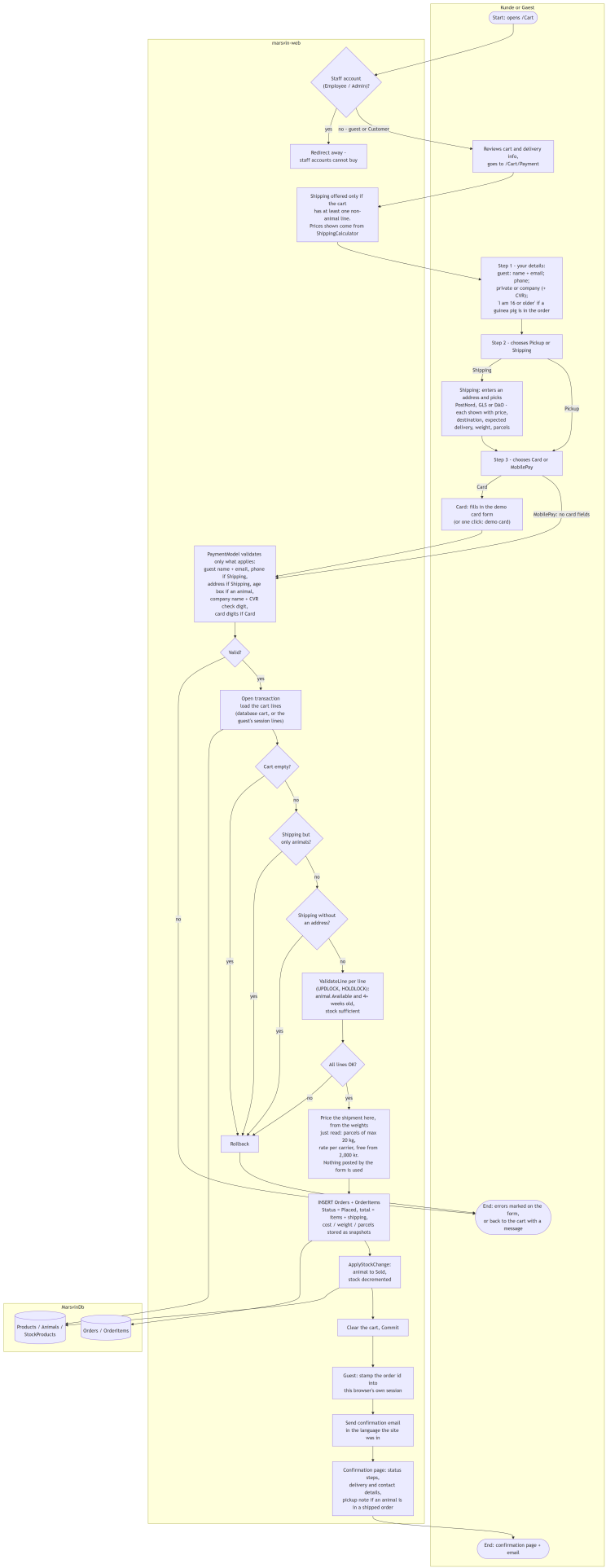
Deployment

marsvin-deployment.mermaid



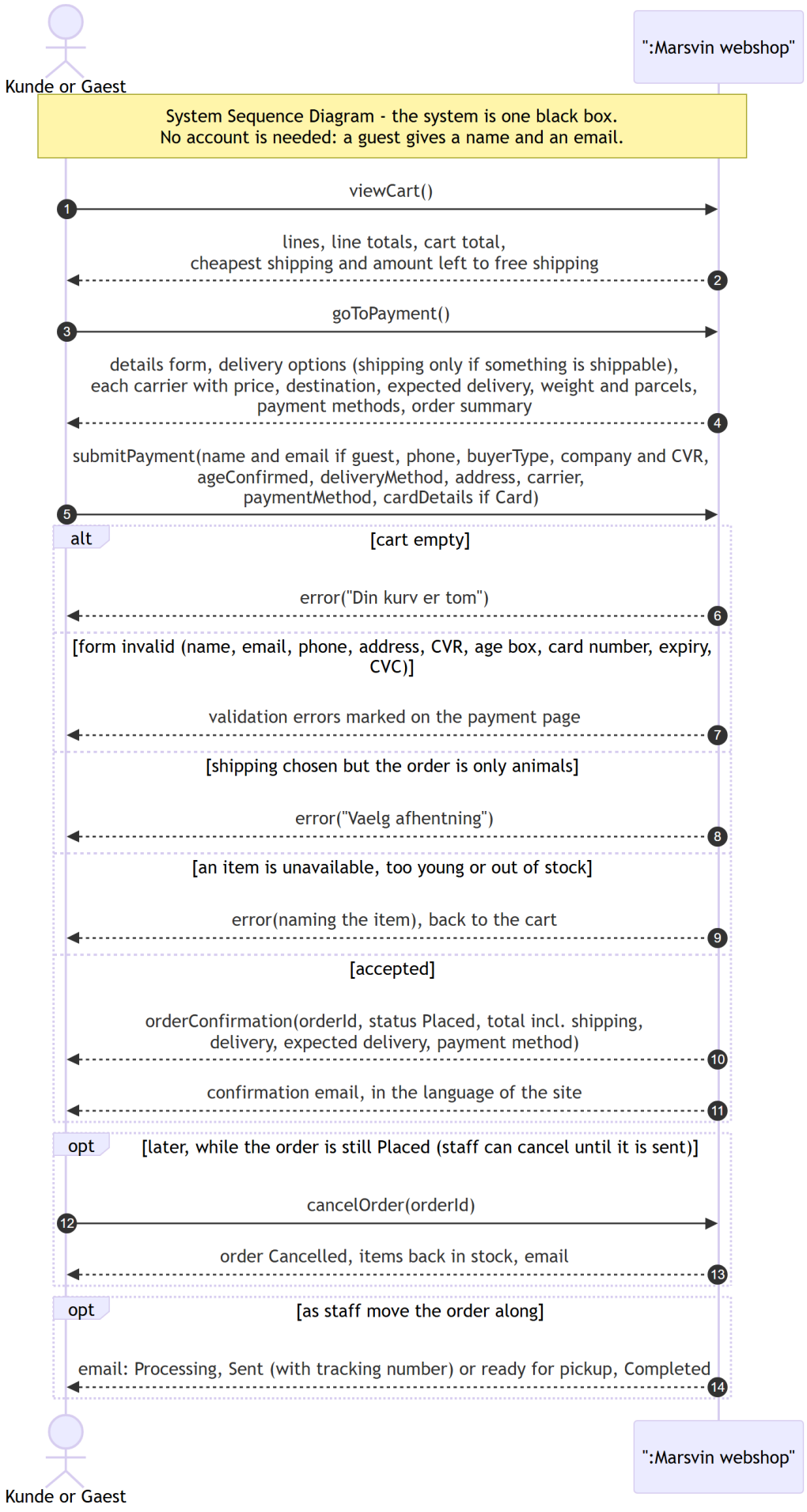
Activity diagram

marsvin-activity-checkout.mermaid



System sequence diagram

marsvin-ssd-place-order.mermaid



Communication diagram

marsvin-communication-checkout.mermaid

